

The Microsoft Exchange Server Hack

James G. Davis

Department of Computer Science, Old Dominion University

CS 462: Cybersecurity Fundamentals

Ms. Susan Zehra

July 27, 2024

The Microsoft Exchange Server Hack

The Microsoft Exchange Server Hack, which was publicly acknowledged on March 2, 2021, remains as one of the most significant cybersecurity attacks in the 2020s. The attackers took advantage of four zero-day vulnerabilities to access tens of thousands of organizations around the world, which allowed them to comprise sensitive data and disrupt business operations. Microsoft identified the Hafnium group as the initial perpetrator, which is a state-sponsored entity that is claimed to be linked to the Chinese government. In this blog, we'll explore the complexities of the attack, investigate the exploited vulnerabilities, the attack's societal impact, and the public responses that were made by both Microsoft and cybersecurity agencies around the world.

Background

Microsoft Exchange Server is known as an e-mail and calendar software that is marketed towards enterprise environments. It also contains various task management and collaboration capabilities. This software can be deployed both on-premises and on the cloud, but this attack affected solutions that were hosted on-premises, as the previously mentioned four zero-day vulnerabilities did not have an effect on Exchange Online. This means that organizations who host Exchange on-site are being targeted by attackers who are aiming to steal data and disrupt business operations.

Vulnerabilities

The attack on Microsoft Exchange Server was associated with the following zero-day vulnerabilities:

- CVE-2021-26855

- CVE-2021-26857
- CVE-2021-26858
- CVE-2021-27065

According to MITRE's CVE list, all of these are briefly summarized as "Microsoft Exchange Server Remote Code Execution Vulnerability" (CVE, 2021). When the attack was publicly acknowledged on 2 March 2021, the Microsoft Security Response Center (MSRC) published an update guide, which defined the target as servers running "Microsoft Exchange Server 2013, 2016, or 2019" (Security Update Guide - Microsoft Security Response Center, 2021).

How the Code Went Undetected

The Hafnium group, which is only one of "more than ten different advanced persistent threat (APT) groups" used sophisticated methods to avoid being detected (ESET, 2021). Attackers could remotely access Exchange Server by using stolen account information, but they could also exploit the previously mentioned zero-day vulnerabilities to pretend to be someone who would normally have access. Once this initial access was made, they could then deploy a web shell that allowed for persistent remote access. This persistent access served as a key factor in the increased difficulty for victimized organizations recovering from this attack.

Impact

The Microsoft Exchange Server Hack had a serious impact in several ways:

- **Global Scale:** This attack affected "more than 5,000 unique servers in over 115 countries" (ESET, 2021). Additionally, there were numerous industries that suffered from

this attack, including “finance, insurance, retail, manufacturing, utilities, travel,” and “construction” (Kobialka, 2021).

- **Data Breach:** The personal information and email communications of anywhere from “tens of thousands to more than 250,000 victims” around the world, especially in governments and small businesses, are believed to have been exposed to the various attackers (International Cyber Law: Interactive Toolkit, 2021).
- **Disruption of Operations:** As a result of organizations attempting to avoid the exposure of confidential information, many of those running Exchange Server on-premises decided to undergo downtime as an emergency response, until the appropriate security measures were implemented on their systems.
- **Multiple Financial Costs:** The financial implications are not only limited to the costs associated with unexpected downtime for organizations, but there were also additional unexpected costs that resulted from other threats aside from data exfiltration. For example, some systems suffered from crypto-mining malware, which included “Lemon Duck and the Monero-mining component of Prometei” (International Cyber Law: Interactive Toolkit, 2021). Furthermore, some Exchange Server implementations were targeted by hackers who deployed various forms of ransomware, such as DearCry, Revil, and Black KingDom. Although it did not comment on the report, Acer was reportedly affected by ransomware during this attack, and it is believed that the company was demanded to pay a ransom of \$50,000,000, which then became known as “the largest known ransom to date” (Abrams, 2021b).

Why This Is Concerning

This attack is especially concerning as a result of its complicated nature through the exploitation of zero-day vulnerabilities. In the context of Hafnium conducting the attack, it highlights the threat of international cyber warfare. Additionally, it didn't take long at all for additional hacking groups to exploit the vulnerabilities for their benefit too; approximately one week after the attack was publicly acknowledged, ESET Research listed various other threat actors, including Tick, LuckyMouse, Calypso, the Winnti Group, Tonto Team, Mikroceen, Websiic, DLTMiner, an unknown group that deployed "a variant of the ShadowPad backdoor," and a few IIS backdoors (ESET, 2021). There was also a threat actor that exploited Exchange's vulnerabilities to conduct what became known as the "Opera" Cobalt Strike; this affected approximately 650 servers, which were mostly located within "the US, Germany, the UK and other European countries" (ESET, 2021). Unfortunately, part of what made this attack so frequent by numerous threat actors is the widespread usage of Microsoft's Exchange Server software, meaning that its vulnerabilities pertain to thousands of servers within organizations around the world.

Improve Cyber Defenses

The Microsoft Security Response Center (MSRC) quickly provided security updates on March 2, 2021, which aimed to address the previously mentioned zero-day vulnerabilities that affected "Exchange 2013, 2016, and 2019" (MSRC Blog, 2021). While the MSRC stated that Exchange Online wasn't vulnerable to these security flaws, they also urged users running Exchange 2010 to apply an update that addresses CVE-2021-26857, specifically. Additionally, they highly recommended against running Exchange 2003 and 2007 regardless of whether they were actually vulnerable to the March 2021 attacks, as these versions lost support many years ago. After

deploying these security patches across all systems, organizations should also monitor various network activities, while paying close attention to any suspicious activities. This includes behaviors such as failed login attempts, particularly those that frequently originate from unknown sources. This relates to Microsoft's recommendation of using "known Indicators of Compromise" as a way to expose "leave-behinds and anomalous behaviors" that would occur after a data breach, such as a back door that was established through the exploitation of one of the zero-day vulnerabilities (Security Boulevard, 2021).

However, it's critical to note that applying the relevant security patches and monitoring web traffic is only the beginning of preventing or recovering from the attack. Particularly for organization's that were impacted by the attack, the security patches alone will not block access to back doors that were already created by an attacker. Instead, Microsoft released a security tool known as MSERT on March 7, 2021, which is designed to locate web shells that attackers created. MSERT, also known as either the Microsoft Support Emergency Response Tool or Microsoft Safety Scanner, should not be confused with the Windows Malicious Software Removal Tool (MSRT). This is because MSERT is a portable tool that uses "Microsoft Defender signatures to scan for and remove detected malware" (Abrams, 2021a). However, it's important to recognize that MSERT cannot provide real-time protection; instead, it's only used to locate web shells and other unwanted software. Then, by default, it will delete anything malicious that it detects, unless the administrator uses a specific PowerShell command to quarantine detected items for further analysis later. To quarantine malicious software, the administrator must navigate to the directory containing 'msert.exe', and then execute it within PowerShell by using the '/N' argument. Through a combination of cybersecurity procedures, including the deployment of the

necessary security patches, network traffic monitoring, and scanning for any potential back doors that an attacker could use even after security updates have been installed, organizations can effectively close down pre-existing web shells, while also ensuring these specific Microsoft Exchange Server vulnerabilities can no longer be exploited.

Public View

The public's understanding of the Microsoft Exchange Server Hack emphasizes the importance of defending critical infrastructure from cyberattacks. Media coverage, governmental advisories, research groups, cybersecurity professionals, and IT corporations have all increased awareness of the significance of cybersecurity within any organization that stores sensitive data on Internet-connected devices.

Purpose and Cost

The main purpose of the attack is believed to have been intelligence gathering, and, in the context of the Hafnium group, espionage, due to its state-sponsored nature. While the immediate financial impact on targeted organizations across a variety of industries was previously covered in this work's *Impact* section, the entirety of the series of events associated with this attack demands that we focus on the broader implications this attack has had on international security and trust in digital infrastructure.

The Future

The Microsoft Exchange Server Hack highlights the importance of continuously patching updates to reduce the potential attack surface. Additionally, we need to continue encouraging

collaborative efforts between governments, the private sector, and cybersecurity analysts to promote strong defenses. For example, in the United States, the Cybersecurity and Infrastructure Security Agency (CISA) equips their partners with the necessary frameworks to reduce risk to critical cyber infrastructure. Organizations should also prioritize investments in various modern security technologies, including cloud solutions, zero-trust architecture, and also implement encryption as much as possible to reduce plaintext data storage and transmission. Also, organizations should continuously train employees on a regular basis about cybersecurity best practices, especially to decrease the risk of credential-based attacks. This is due to the way that some attackers were able to exploit Exchange's vulnerabilities by using stolen account information. Therefore, regular training sessions should consist of a variety of relevant topics, including safe browsing habits, phishing, and other forms of social engineering.

References

- Abrams, L. (2021a, March 7). *Microsoft's MSERT tool now finds web shells from Exchange Server attacks*. BleepingComputer. <https://www.bleepingcomputer.com/news/security/microsofts-msert-tool-now-finds-web-shells-from-exchange-server-attacks/>
- Abrams, L. (2021b, March 19). *Computer giant Acer hit by \$50 million ransomware attack*. BleepingComputer. <https://www.bleepingcomputer.com/news/security/computer-giant-acer-hit-by-50-million-ransomware-attack>
- CVE. (2021, February 10). *CVE - Search Results*. <https://cve.mitre.org/cgi-bin/cvekey.cgi?keyword=CVE-2021-26855%2BCVE-2021-26857%2BCVE-2021-26858%2BCVE-2021-27065>
- ESET. (2021, March 10). *Number of APT groups exploiting the latest Exchange vulnerabilities grows, with thousands of email servers under siege, ESET discovers*. <https://www.eset.com/int/about/newsroom/press-releases/research/number-of-apt-groups-exploiting-the-latest-exchange-vulnerabilities-grows-with-thousands-of-email-s/>
- International Cyber Law: Interactive Toolkit. (2021, August 12). *Microsoft Exchange Server data breach (2021)*. [https://cyberlaw.ccdcoe.org/wiki/Microsoft_Exchange_Server_data_breach_\(2021\)](https://cyberlaw.ccdcoe.org/wiki/Microsoft_Exchange_Server_data_breach_(2021))
- Kobialka, D. (2021, April 22). *Hackers use Prometei botnet to attack Microsoft Exchange users*. MSSP Alert. <https://www.msspalert.com/news/prometei-botnet-microsoft-exchange-users>
- MSRC Blog. (2021, March 2). *On-premises Exchange Server vulnerabilities resource center – updated March 25, 2021*. Microsoft Security Response Center. <https://msrc.microsoft.com/blog/2021/03/multiple-security-updates-released-for-exchange-server/>
- Security Boulevard. (2021, December 31). *What we can learn from the 2021 Microsoft data*

breach. <https://securityboulevard.com/2021/12/what-we-can-learn-from-the-2021-microsoft-data-breach/>

Security Update Guide - Microsoft Security Response Center. (2021, March 2). *CVE-2021-26855 - Security update guide - Microsoft - Microsoft Exchange Server remote code execution vulnerability.* <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-26855>